

DIAGNÓSTICO LIGERO DE MADUREZ EN CIBERSEGURIDAD PARA MIPYMES DEL SECTOR SERVICIOS EN COLOMBIA: ESTUDIO DE CASO EN BOGOTÁ D.C.

Jair Alexis Martínez Morales
Jamartinezmora@unadvirtual.edu.co
Daniel Ricardo Diaz Ovalle
Drdiaz@unadvirtual.edu.co

RESUMEN: El crecimiento de los incidentes de ciberseguridad en Colombia afecta de forma desproporcionada a las micro, pequeñas y medianas empresas (MiPymes) del sector servicios. Este artículo presenta el diseño de un prototipo de diagnóstico ligero de madurez en ciberseguridad para MiPymes, basado en el NIST Cybersecurity Framework (NIST CSF). El estudio adopta un enfoque mixto con prioridad cuantitativa, mediante una encuesta de 22 ítems agrupados en cuatro dimensiones: cultura y gestión de la seguridad, protección de la información y accesos, continuidad y respaldo operativo, y riesgos y amenazas. Las respuestas se procesan en un prototipo web desarrollado con Angular, Laravel y MySQL, que calcula un índice de madurez, genera visualizaciones y propone recomendaciones priorizadas de alto impacto y bajo costo. El prototipo se valida mediante un estudio de caso con tres MiPymes del sector servicios ubicadas en Bogotá D.C., confirmando su aplicabilidad en contextos empresariales reales del país.

PALABRAS CLAVE: Ciberseguridad, MiPymes, NIST CSF, Diagnóstico de madurez.

1 INTRODUCCIÓN

Las micro, pequeñas y medianas empresas (MiPymes) constituyen más del 90 % del tejido empresarial colombiano y son actores clave en la generación de empleo y valor agregado en el país. Sin embargo, diversos estudios evidencian que su gestión de la ciberseguridad es incipiente, con bajos niveles de madurez, escasa formalización de políticas y controles, y alta vulnerabilidad frente a incidentes como ransomware, phishing y fugas de información [1], [2].

La acelerada adopción de servicios en la nube, el trabajo remoto y los pagos electrónicos ha ampliado la superficie de ataque de las MiPymes, incrementando su exposición a amenazas que comprometen la confidencialidad, integridad y disponibilidad de la información. En este contexto, marcos de referencia como el NIST Cybersecurity Framework (NIST CSF) y sus guías específicas para pequeñas organizaciones ofrecen una estructura flexible para gestionar el riesgo de ciberseguridad mediante las funciones Identify, Protect, Detect, Respond y Recover [3], [4].

No obstante, la adopción directa de estándares o marcos complejos suele ser inviable para MiPymes de servicios que carecen de equipos dedicados de seguridad, presupuesto estable y capacidades técnicas avanzadas. La literatura reciente

propone modelos de madurez y herramientas de diagnóstico orientadas a pequeñas y medianas empresas, generalmente basadas en cuestionarios estructurados y plataformas web ligeras que traducen marcos como NIST CSF en listas de verificación y planes de mejora comprensibles para usuarios no especialistas [5]–[8].

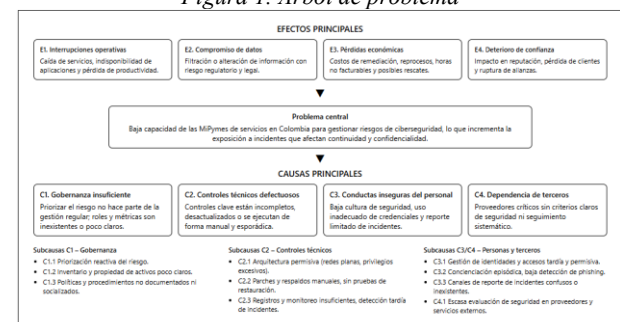
Este artículo se enfoca en las MiPymes del sector servicios en Bogotá y tiene como propósito describir el diseño de un prototipo funcional de diagnóstico ligero de madurez en ciberseguridad, alineado al NIST CSF y adaptado a contextos con recursos limitados. A partir de un instrumento de evaluación aplicado a tres MiPymes, el prototipo genera un índice de madurez por dimensiones, visualizaciones comparativas y recomendaciones priorizadas de alto impacto–bajo costo en controles esenciales (segmentación de red, MFA/VPN, parchado, respaldos probados y centralización de registros).

El artículo se organiza de la siguiente manera: la Sección 2 presenta el marco teórico y los trabajos relacionados; la Sección 3 describe la metodología de investigación y el instrumento de medición; la Sección 4 detalla el diseño del prototipo y sus módulos; la Sección 5 expone los resultados esperados y el alcance tecnológico; finalmente, la Sección 6 resume las conclusiones y plantea líneas de trabajo futuro.

Aunque el problema se presenta a nivel nacional, este estudio se implementa y valida mediante un análisis aplicado a tres MiPymes del sector servicios ubicadas en Bogotá D.C., lo que permite evaluar el prototipo en un escenario representativo del contexto colombiano.

La Figura 1 resume el árbol de problema que orienta el proyecto.

Figura 1. Árbol de problema



Fuente: Autoría Propia

2 MARCO TEÓRICO Y TRABAJOS RELACIONADOS

2.1 Ciberseguridad y MiPymes de servicios en Colombia

Estudios recientes sobre gestión de ciberseguridad en MiPymes colombianas evidencian niveles de madurez bajos a intermedios, con prácticas fragmentadas, escasa documentación de políticas y una alta dependencia de proveedores externos para servicios clave de TI [1], [2].

Las brechas más frecuentes se relacionan con:

- Ausencia de políticas y procedimientos formales de seguridad de la información.
- Gestión reactiva del riesgo, enfocada en incidentes puntuales y no en procesos críticos.
- Controles técnicos básicos incompletos o mal configurados (respaldos, parchado, antivirus, autenticación).
- Bajo nivel de concienciación del personal frente a ingeniería social y uso seguro de credenciales.

En sectores de servicios como comercio electrónico, marketing digital, salud no hospitalaria y turismo, la exposición a fraudes, robo de información de clientes y secuestro de datos limita la continuidad del negocio y deteriora la confianza de clientes y aliados [1], [9].

2.2 Modelos de madurez y herramientas de diagnóstico para SMEs

A nivel internacional se han propuesto múltiples modelos de madurez en ciberseguridad e información, varios de ellos alineados explícitamente con el NIST CSF. El Information Security Maturity Model (ISMM) define una escala de cinco niveles para medir la implementación del NIST CSF en diferentes dominios, proporcionando una vista estructurada del avance de una organización [5], [6].

Otros trabajos plantean herramientas de evaluación específicas para SMEs basadas en cuestionarios en línea que generan un puntaje de madurez y un conjunto de recomendaciones priorizadas. Benz y Chatterjee, por ejemplo, proponen un “Cybersecurity Evaluation Tool (CET)” para SMEs que utiliza 35 preguntas esenciales mapeadas a NIST CSF [7], mientras que diversas plataformas web recientes integran dashboards y reportes automáticos para apoyar decisiones de negocio en organizaciones con recursos limitados [8].

En el contexto colombiano, investigaciones sobre diagnóstico de ciberseguridad en PYMES y sobre planes de implementación han resaltado la importancia de enfoques graduales que combinen instrumentos ligeros de evaluación con acciones concretas en controles de alto impacto como respaldos, gestión de accesos y monitoreo [1], [10].

La literatura revisada resulta especialmente relevante para el contexto colombiano, ya que las MiPymes del país enfrentan desafíos similares en disponibilidad de recursos, infraestructura tecnológica, cultura de seguridad y capacidad de adopción de buenas prácticas, lo que hace pertinente la adaptación de estos modelos internacionales.

2.3 NIST Cybersecurity Framework y guías para pequeñas organizaciones

El NIST CSF se ha consolidado como un marco flexible y agnóstico al tamaño de la organización, estructurado en cinco funciones (Identify, Protect, Detect, Respond y Recover) y categorías y subcategorías que permiten mapear controles y prácticas de seguridad según el perfil de riesgo y el contexto operacional [3], [4], [11].

Guías específicas de NIST y otros organismos adaptan el NIST CSF para pequeñas empresas, enfatizando la priorización de controles costo-efectivos, uso de herramientas de bajo costo y adopción progresiva de capacidades de monitoreo y respuesta [3], [11], [12]. Estas guías recomiendan el uso de listas de verificación, plantillas de evaluación y hojas de cálculo que permitan a las SMEs autoevaluar su estado y planear mejoras sin requerir consultorías extensivas.

El prototipo propuesto en este trabajo sigue esa línea: utiliza un cuestionario estructurado alineado a principios del NIST CSF, simplifica la medición de madurez en cuatro dimensiones y automatiza la generación de reportes y recomendaciones, con el objetivo de hacerlo accesible a MiPymes de servicios en Colombia.

3 METODOLOGÍA

3.1 Enfoque y diseño de estudio

La investigación adopta un enfoque mixto con prioridad cuantitativa (QUAN → qual, explicativo secuencial). En la primera fase se aplica una encuesta estructurada de madurez en ciberseguridad a MiPymes del sector servicios; en la segunda fase, se analizan respuestas abiertas para interpretar las causas de las brechas cuantitativas y refinar recomendaciones [13].

El diseño es no experimental, observacional, transversal y analítico, con múltiples casos (tres empresas: micro, pequeña y mediana). El corte transversal permite estimar el estado de ciberseguridad en cada organización y comparar perfiles de madurez entre tamaños de empresa.

Las tres organizaciones seleccionadas se encuentran ubicadas en Bogotá D.C., y fueron elegidas por accesibilidad, disposición a participar y representatividad dentro del sector servicios, permitiendo un estudio de caso múltiple adecuado para validar el prototipo.

3.2 Población y muestra

La población objetivo está conformada por MiPymes del sector servicios en Colombia con infraestructura tecnológica activa (computadores, redes, servicios en la nube, pagos

electrónicos). La muestra es intencional e incluye tres organizaciones ubicadas en Bogotá D.C. (una micro, una pequeña y una mediana empresa), seleccionadas por accesibilidad y disposición a participar. Las unidades de análisis son la empresa (nivel organizacional) y las dimensiones del instrumento (subnivel).

La relación entre población nacional y muestra localizada se establece mediante un estudio de caso múltiple, lo que posibilita analizar la aplicabilidad del prototipo en un entorno real manteniendo la generalización teórica hacia las MiPymes colombianas.

3.3 Instrumento de medición

Se diseñó un instrumento de diagnóstico tipo encuesta alineado a principios del NIST CSF y adaptado al nivel de madurez tecnológica de las MiPymes objetivo. El instrumento contiene 22 preguntas:

- 20 ítems cerrados en escala Likert de 1 a 5.
- 2 preguntas abiertas sobre barreras y necesidades de apoyo en ciberseguridad.

Las 20 preguntas cerradas se agrupan en cuatro dimensiones:

1. Cultura y gestión de la seguridad
2. Protección de la información y accesos
3. Continuidad y respaldo operativo
4. Riesgos y amenazas

Cada ítem se valora de 1 (“No se aplica”) a 5 (“Consolidado”). A partir de las respuestas se calcula un índice de madurez por dimensión y un índice global expresado en porcentaje, clasificado en cinco niveles: Inicial, Básico, Intermedio, Avanzado y Consolidado.

La encuesta se implementa en Google Forms, con almacenamiento de datos en una hoja de cálculo vinculada que se integrará posteriormente con el prototipo web para automatizar cálculos y visualizaciones.

Tabla 1. Dimensiones e ítems del instrumento de diagnóstico

DIMENSIÓN	DESCRIPCIÓN	N.º ÍTEMES
Cultura y gestión de la seguridad	Evalúa conciencia, roles, políticas básicas y grado de formalización de la seguridad en la organización.	5
Protección de la información y accesos	Examina controles esenciales como contraseñas, accesos, antivirus, dispositivos y protección de datos.	5
Continuidad y respaldo operativo	Mide prácticas relacionadas con copias de seguridad, recuperación de datos y disponibilidad de servicios.	5
Riesgos y amenazas	Identifica conocimiento sobre amenazas digitales y la existencia de acciones preventivas para	5

mitigarlas.

Fuente: elaboración propia a partir del instrumento de encuesta.

3.4 Procedimiento de recolección y análisis de datos

1. Convocatoria y explicación del estudio a gerentes y responsables de TI.
2. Obtención de consentimiento informado y aplicación virtual del formulario.
3. Exportación de respuestas a la base de datos del prototipo.
4. Cálculo automático de índices de madurez globales y por dimensión.
5. Análisis descriptivo (medias, porcentajes) y construcción de mapas de brechas (semáforos).
6. Análisis temático ligero de respuestas abiertas para identificar barreras (presupuesto, tiempo, conocimiento, dependencia de terceros).

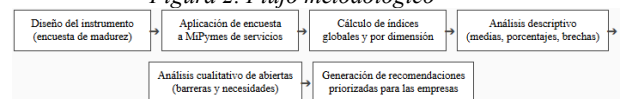
El componente cuantitativo se apoya en estadísticas descriptivas y visualizaciones (gráficos de barras y radar). El componente cualitativo se utiliza para interpretar diferencias de madurez y ajustar las recomendaciones generadas por el prototipo.

3.5 Consideraciones éticas

Se cumplen los lineamientos de la Ley 1581 de 2012 y el Decreto 1377 de 2013 en materia de protección de datos personales, aplicando principios de finalidad, confidencialidad y minimización. Los resultados se presentan de forma agregada y las empresas se anonimizarán en los reportes. Las respuestas serán almacenadas en repositorios controlados para uso exclusivamente académico.

La Figura 2 presenta el flujo metodológico seguido en el estudio.

Figura 2. Flujo metodológico



Fuente: Autoría Propia

4 DISEÑO DEL PROTOTIPO DE DIAGNÓSTICO

4.1 Arquitectura general

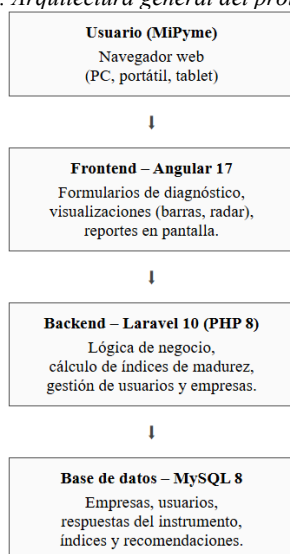
El prototipo se concibe como una aplicación web ligera, modular y escalable, orientada a proporcionar un diagnóstico rápido y comprensible del nivel de madurez en ciberseguridad de MiPymes de servicios, sin requerir infraestructura especializada.

La arquitectura propuesta se compone de:

- **Frontend:** Angular 17, responsable de la interfaz de usuario, formularios de diagnóstico, visualización de gráficos y generación de reportes en pantalla.
- **Backend:** PHP 8 con el framework Laravel 10, que implementa la lógica de negocio, cálculo de índices, gestión de usuarios y generación de reportes.
- **Base de datos:** MySQL 8, donde se almacenan empresas, usuarios, respuestas del instrumento, índices de madurez y recomendaciones.
- **Servidor de aplicación:** despliegue en servidor local o en la nube utilizando Apache/XAMPP en etapas iniciales.

La arquitectura general del prototipo se muestra en la Figura 3.

Figura 3. Arquitectura general del prototipo web



Fuente: elaboración propia. Despliegue en servidor local o en la nube (Apache/XAMPP).

4.2 Requerimientos funcionales

Los principales módulos funcionales del sistema son:

1. **Módulo de diagnóstico:**
 - Permite a los usuarios autorizados diligenciar en línea el cuestionario de 20 ítems.
 - Registra las respuestas por empresa y fecha.
 - Calcula automáticamente el puntaje por dimensión y el índice global de madurez.
2. **Módulo de análisis de resultados:**
 - Genera tablas y gráficos comparativos por empresa y por dimensión.
 - Presenta visualizaciones tipo semáforo (rojo, amarillo, verde) para identificar brechas críticas.
3. **Módulo de recomendaciones:**

- Asocia cada rango de madurez con un conjunto de acciones de alto impacto y bajo costo (por ejemplo, habilitar MFA, implementar respaldos 3-2-1, revisar privilegios y segmentación básica de red).
- Genera un plan de mejora priorizado por dominio y esfuerzo requerido.

4. Módulo de gestión de usuarios y empresas:

- Permite registrar nuevas organizaciones y usuarios con roles (administrador, evaluador).
- Mantiene trazabilidad de diagnósticos realizados (histórico por empresa).

5. Módulo de exportación y reportes:

- Genera reportes en PDF y/o Excel con resultados, gráficos y recomendaciones para su presentación a directivos, auditores o tutores académicos.

Figura 4. Módulos funcionales del prototipo

Módulo	Funcionalidad principal	Salidas
Diagnóstico	Permite diligenciar en línea el cuestionario de 20 ítems, registrar respuestas por empresa y fecha, y calcular automáticamente puntajes por dimensión e índice global.	Respuestas almacenadas por empresa, análisis de madurez global y por dimensión.
Análisis	Genera tablas y gráficos comparativos entre empresas y dimensiones; visualizaciones tipo semáforo para brechas críticas.	Gráficos de barras y radar, mapas de brechas (semáforos).
Recomendaciones	Asocia rangos de madurez con acciones de alto impacto y bajo costo (MFA, respaldos 3-2-1, segmentación básica, etc.).	Plan de mejora priorizado por dominio y esfuerzo requerido.
Gestión de usuarios y empresas	Registro de organizaciones y usuarios con roles; mantiene la trazabilidad de diagnósticos realizados.	Lista de empresas y usuarios, histórico de evaluaciones.
Reportes	Exporta resultados en formatos imprimibles (PDF/Excel) para uso de directivos, auditores o tutores.	Reportes descargables con resultados, gráficos y recomendaciones.

Fuente: elaboración propia a partir de los requerimientos funcionales del sistema.

4.3 Requerimientos no funcionales

- **Usabilidad:** interfaz simple, intuitiva, compatible con navegadores modernos, orientada a usuarios no técnicos.
- **Seguridad:** autenticación básica de usuarios, control de sesiones y cifrado de credenciales.
- **Disponibilidad:** operación estable con un mínimo de 95 % de disponibilidad, considerando que se trata de un prototipo académico desplegado en entorno controlado.
- **Compatibilidad:** posibilidad de ejecución tanto en entornos locales como en servidores web sin instalaciones complejas.
- **Mantenibilidad y escalabilidad:** código modular siguiendo principios de Clean Code para facilitar futuras extensiones (por ejemplo, autenticación multifactor, análisis comparativo entre sectores).

4.4 Nivel de madurez tecnológica (TRL5)

El prototipo se diseña para alcanzar un nivel de madurez tecnológica TRL5, demostrando su funcionamiento en un entorno relevante a través de:

- Implementación efectiva de los módulos descritos.
- Carga de datos reales provenientes de las tres MiPymes de la muestra.

- Ejecución de diagnósticos completos y generación de reportes interpretables.

5 RESULTADOS ESPERADOS

En el plano tecnológico, se espera obtener:

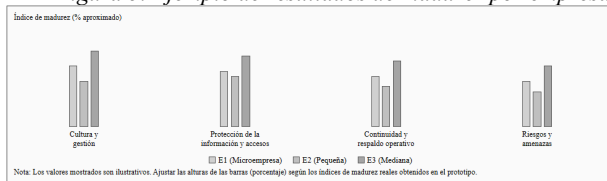
- Un prototipo web funcional que permita a cada MiPyme:
 - diligenciar el cuestionario,
 - visualizar su índice de madurez global y por dimensión,
 - descargar un informe detallado con brechas y recomendaciones alineadas al NIST CSF.
- Visualizaciones comparativas entre las tres empresas, que permitan identificar patrones de madurez y brechas comunes en el sector servicios.

En el plano investigativo y práctico, se espera:

- Proporcionar una línea base del estado de madurez en ciberseguridad de MiPymes de servicios en Bogotá, complementando estudios previos realizados a nivel nacional [1], [2].
- Validar la utilidad de instrumentos ligeros y prototipos web basados en NIST CSF como mecanismo de diagnóstico y sensibilización en organizaciones con recursos limitados.
- Generar recomendaciones replicables que sirvan como guía para políticas públicas y programas de acompañamiento a MiPymes en ciberseguridad.

Los resultados obtenidos en Bogotá D.C. constituirán un insumo preliminar para futuras caracterizaciones de madurez en ciberseguridad a nivel nacional, sirviendo como base para ampliaciones en diferentes regiones y sectores.

Figura 5. Ejemplo de resultados de madurez por empresa



Fuente: elaboración propia a partir de resultados esperados del diagnóstico.

6 CONCLUSIONES Y TRABAJO FUTURO

Este artículo ha presentado el diseño de un prototipo de diagnóstico ligero de madurez en ciberseguridad para MiPymes del sector servicios en Bogotá, basado en el NIST Cybersecurity Framework y desarrollado mediante una arquitectura web ligera con tecnologías abiertas. El enfoque mixto adoptado, la estructura del instrumento de medición y la integración de resultados en una plataforma interactiva buscan cerrar la brecha entre marcos internacionales de buenas prácticas y la capacidad real de implementación de las MiPymes colombianas.

Entre los aportes esperados se encuentran: (i) una herramienta reutilizable de autoevaluación y priorización de controles de alto impacto–bajo costo, (ii) una metodología replicable para futuros diagnósticos sectoriales y (iii) evidencia empírica sobre patrones de madurez en MiPymes de servicios.

Como trabajo futuro se propone:

- Extender la muestra a un número mayor de MiPymes y otros sectores (por ejemplo, manufactura, educación, salud).
- Incorporar capacidades adicionales en el prototipo, tales como autenticación multifactor, módulos de capacitación y simulaciones de phishing.
- Explorar la integración del prototipo con métricas de riesgo y continuidad de negocio, así como con otros marcos de referencia y regulaciones nacionales.

Los hallazgos derivados del estudio de caso en Bogotá D.C. permitirán ajustar y robustecer el prototipo, con el fin de extender su uso hacia MiPymes del resto del país, fortaleciendo su potencial de adopción en contextos regionales diversos.

De este modo, el proyecto sienta las bases para convertir la ciberseguridad en un habilitador de continuidad y confianza en el ecosistema de MiPymes de servicios en Colombia.

En conjunto, este estudio aporta una herramienta de diagnóstico aplicable a nivel nacional y valida su utilidad en un entorno local, sentando las bases para futuras implementaciones ampliadas en el ecosistema MiPyme colombiano.

7 REFERENCIAS

- [1] Díaz-Piraquive, F. N., & colaboradores. (2023). *Cybersecurity management in micro, small, and medium enterprises in Colombia*. Universidad Internacional de La Rioja.
- [2] Sánchez-Sánchez, P. A., García-González, J. R., Triana, A., & Pérez-Coronell, L. (2021). Medida del nivel de seguridad informática de las pequeñas y medianas empresas (PYMES) en Colombia. *Información Tecnológica*, 32(5), 121–132.
- [3] National Institute of Standards and Technology. (2018). *Framework for Improving Critical Infrastructure Cybersecurity* (Version 1.1). NIST.
- [4] National Institute of Standards and Technology. (2024). *Marco de Seguridad Cibernética (CSF) 2.0* (Versión en español). NIST.
- [5] Bistarelli, S., et al. (2025). Analysis and Study of a Cybersecurity Maturity Assessment Model. In *Proceedings of CEUR Workshop* (Vol. 3962).
- [6] Almuhammadi, S., & Alsaleh, M. (2017). Information Security Maturity Model for NIST Cyber Security Framework. *Computer Science & Information Technology (CS & IT)*, 7(3), 51-62.
- [7] Benz, M., & Chatterjee, D. (2020). Calculated risk? A cybersecurity evaluation tool for SMEs. *Business Horizons*, 63(3), 425–436.
- [8] Venkatesh, V. (2018). Design of Cybersecurity Risk Assessment Tool for Small and Medium Sized Businesses using the NIST Cybersecurity Framework.
- [9] Gordillo, A. (2024). Estrategias de ciberseguridad para MiPymes del sector terciario. *Revista EPSIR*.
- [10] Niño Prada, Y. M. (2025). Plan de implementación de ciberseguridad para una Pyme colombiana. Universidad El Bosque.

- [11] NIST. (2024). *Small Business Quick-Start Guide: Cybersecurity Framework 2.0*.
- [12] NIST. (2018). *Assessment & Auditing Resources for the NIST Cybersecurity Framework*.
- [13] *Documento maestro Fase_4 del proyecto de grado "Diagnóstico del estado de ciberseguridad en la infraestructura tecnológica de empresas colombianas". Universidad Nacional Abierta y a Distancia (UNAD)*.
- [14] J. A. Martínez Morales y D. R. Díaz Ovalle, "Repositorio GitHub proyecto_Diagnostico: Prototipo de diagnóstico ligero de madurez en ciberseguridad para MiPymes," GitHub, 2025. [En línea]. Disponible en:
https://github.com/alexis2487/proyecto_Diagnostico